PCI DSS & HIPAA Compliance Assessment

Student Name: Jemimah Jacobs

Course Code: (C26-06)

Submission Date: August 2nd, 2026

Incident 1 — PCI DSS: Payment System

1. Which PCI DSS requirements apply to this situation?

Since MediCare Plus takes card payments both at reception and through its online portal, and passes that data to a third-party processor, several PCI DSS requirements come into play:

PCI DSS Requirement	Objective	Application to MediCare Plus
Requirement 1	Install and Maintain Network Security Controls	The payment environment needs to be segmented off from clinical and IT networks, and from public Wi-Fi, since reception and the portal both touch cardholder data, so this segmentation matters.
Requirement 2	Secure Configurations	Default vendor passwords on POS terminals need changing, and terminals should be hardened before use.
Requirement 3	Protect Stored Data	Since a third-party vendor handles processing, there's really no need to retain cardholder data at all. Where any is stored, the PAN should be unreadable, encrypted, truncated, masked, or hashed. CVV must never be stored after authorisation.
Requirement 4	Protect Data in Transit	Cardholder data needs strong encryption whenever it crosses an open network using strong cryptography.

Requirement 5	Protect Against Malware	Reception systems and the online payment channel both need protection from malicious software.
Requirement 6	Secure Systems & Software	The patient portal is a live web application, so it needs defending against SQL injection, XSS, and similar vulnerabilities, with patches applied promptly.
Requirement 7	Restrict Access	Only staff with a documented business need like billing and reception, not clinical or IT staff generally, should be able to reach cardholder data or payment systems.
Requirement 8	Identify & Authenticate	Unique logins and MFA should be enforced for anyone touching payment terminals or the portal's admin panel.
Requirement 9	Restrict Physical Access	Relevant at reception, e.g. securing POS terminals, receipts that show PANs, and any physical media.
Requirement 12	Support with Policy	Support information security policy, third-party assessments, an incident response plan, and ongoing staff awareness training.

2. How should MediCare Plus protect cardholder data?

This comes down mainly to Requirements 3 and 4, protecting data at rest and encrypting it in transit, but a few practical steps make the biggest difference:

- Reduce scope through tokenisation or P2PE: At reception, a PCI-validated Point-to-Point Encryption solution would encrypt card data right at the terminal, sending it straight to the processor and keeping the hospital's internal network out of scope. On the portal, using hosted iframe fields or a redirect to the processor (Stripe-style) means card data never touches MediCare Plus's own servers.
- No storage of the security code: This applies to the CVV specifically, broader cardholder data like the PAN, name, and expiry may be stored if properly protected, as noted in Requirement 3.
- Segment the payment network: VLANs and firewalls should isolate the cardholder data environment so medical devices and general admin systems can't reach payment channels.
- Manage vendors properly: Annual Attestation of Compliance should be verified for every payment gateway and cloud provider that touches cardholder data, backed by third-party assessment.

Incident 2 — HIPAA: Patient Records

3. Is the information being accessed PHI? Why?

Yes, this information is Protected Health Information (PHI).

Under the HIPAA Privacy Rule, PHI is defined as individually identifiable health information created, received, stored, or transmitted by the hospital.

Because patient medical records contain both health data and treatment plan (diagnoses, prescriptions, treatment notes) and personal identifiers (names, medical record numbers, addresses, DOBs), any unauthorized internal viewing constitutes an improper exposure of PHI.

4. Which HIPAA safeguard(s) apply to this situation?

Administrative Safeguards
Technical Safeguards

Applicable HIPAA Safeguards

Safeguard Category	Regulatory Reference	Application to Incident
Administrative Safeguards	• Workforce Security & Access Management • Minimum Necessary Standard	Access should be limited to what each role actually requires, least privilege, with sanctions in place for employees who don't comply.
Technical Safeguards	• Access Control • Audit Controls	The EHR system needs technical mechanisms that restrict user privileges and track who accessed which records, and when.

5. What should MediCare Plus do to restrict access to patient records?

Action Plan to Restrict Access to Patient Records
MediCare Plus must immediately undertake the following remediation steps:

1. Role-based access control: Technical & Administrative Control.
   Reconfigure the EHR so permissions follow the job. That means that the Billing staff should only view billing fields not detailed clinical notes, clinical staff should only access records for patients under their direct care unit.
2. Enforce the Minimum Necessary Rule: Administrative Policy.
   Elevated access should require formal manager approval and a stated justification.
3. Enable Audit Logging & Reviews: Technical Safeguard.
   Configure automated logging within the EHR to record every attempt to view, modify, or export PHI. Set up automated alerts for odd access patterns (e.g., viewing records outside shift hours or searching high-profile patient profiles).
4. Conduct Mandatory Workforce Re-Training:Administrative Safeguard.
   Re-train all medical, administrative, billing, and IT personnel on privacy rules and the "Minimum Necessary" policy. With real disciplinary consequences for unauthorised viewing.

References

PCI Security Standards Council, *PCI DSS v4.0.1 Requirements and Testing Procedures* (2024).

U.S. Department of Health and Human Services, *HIPAA Privacy Rule*, 45 C.F.R. § 164.502(b) (Minimum Necessary Standard).